

Narrativa explicativa de la Encuesta CTEM

La gestión de vulnerabilidades es un trabajo de todos. Se contaban cosas (vulnerabilidades, parches, hallazgos), se hacían listas respetables y todos se iban a la reunión de que la suma de números equivalía a seguridad. CTEM viene a recordarnos que lo que de verdad importa no es cuántas vulnerabilidades hay, sino que los ataques reales conducen a los activos que, si caen, nos dejan sin negocio, sin servicio o sin reputación.

Esta encuesta nace precisamente de ese giro: pasar de preguntarnos “¿cuántas vulnerabilidades tienes?” a “¿qué exposición real estás gestionando, con qué criterio, y cómo lo sabes?”. El objetivo no es humillar a nadie, sino colaborar razonablemente pulido delante de organizaciones que, nos consta, están ya bastante ocupadas sobreviviendo al día a día.

Por qué CTEM y no otro

CTEM se ha consolidado, desde 2025, como el marco que mejor captura la intuición de muchos CISOs: no se puede arreglar todo, pero sí se puede decidir antes. El ciclo de alcance, descubrimiento, priorización, validación y movilización es, en el fondo, una versión de tres preguntas:

1. ¿Qué es lo que realmente me impide hacer más daño?
2. ¿Qué estoy haciendo, de forma medible, para que eso sea cada vez menos probable?

La encuesta se organiza para poder dar, más o menos articulada, a cada una de esas preguntas a nivel de organización, y, por agregación, a nivel sectorial o nacional.

Cómo leer los bloques de la encuesta: los datos generales no están ahí por burocracia, sino porque el contexto importa: una pyme subcontractada para un servicio crítico puede tener una exposición tan delicada como un ministerio, pero sus recursos y su marco son distintos. Sin esa información, comparar sería un juego de espejos deformados.

El bloque de “gobierno” muestra quién manda de verdad en CTEM. Si el programa no tiene patrocinio, comité de dirección de vez en cuando, lo normal es que acabe como tantas burocracias: una carpeta, en un SharePoint, y en la memoria de quien lo intentó.

Los bloques de “alcance” y “despliegue” giran en torno a una obsesión: si no sabes lo que tienes, lo descubrirás el día menos oportuno, normalmente de madrugada y con alguien gritando en mayúsculas. Preguntamos para identificar activos críticos, cómo se actualizan inventarios y qué se sabe de la superficie de ataque, fuera y dentro. El objetivo es distinguir entre “lo tenemos controlado” y “hemos comprobado que lo tenemos controlado”.

La **priorización** es donde CTEM se juega- [] Parcialma. Las preguntas exploran si se siguen sólo métricas técnicas (CVSS y familia) o si se combina esa información con el cont- [] Parcialmo, inteligencia de amenazas y una mínima conciencia de que los recursos son fin- [] Parcialme si la organización ha pasado de la lógica del “todo es crí- [] Parcialmómoda pero honesta práctica de admitir que no todo lo es.

En l- [] Parcialm** buscamos señales de una cultura adversarial madura: no basta con asumir que los controles funcionan;- [] Parcialms fallar, aprender y mejorar. Las cuestiones sobre BAS, ejercicios de ataque, m- [] Parcialmefic- [] Parcialmles y actualización de escenarios pretenden separar el “nos han dicho que va b- [] Parcialmmemos probado y sabemos dónde se rompe”.

La **movilización** y la **remedia- [] Parcialmlugar donde los indicadores dejan de- [] Parcialms. Hablamos de SLAs, de cumplimiento de plazos, de tiempo m- [] Parcialmación y de la velocidad a la que se reduce la exposición. Si CTEM no re- [] Parcialmy visiblemente, el número de rutas de ataque explotables hacia activos críticos, ento- [] Parcialmprograma: es un PowerPoint.

El bloque de **resiliencia y continuidad** introduc- [] Parcialm temporal y humana: qué pasa cuando algo se rompe, cuánto tardamos en levantarlo y qué rela- [] Parcialmo con la forma en que gestionamos la exposición. La idea es p- [] Parcialmonar, en el futuro, niveles de madurez CTEM- [] Parcialmncia y gravedad de los incidentes que afectan a servicios esenciales.

El bloqu- [] Parcialmiento normativo** evita el clásico divorcio entre el mundo del cumplimi- [] ParcialmRA, ISO, NIST...) y el del riesgo operativo. Las pregunta- [] Parcialmr si CTEM vive en una isla creativa o si se le permite jugar con los mayores y, de paso, facilitar la vida a qui- [] Parcialmn auditorías y supervisores.

El bloque de **tecnología y datos** se adentra en un terreno resbaladizo: la tentación de medir la madurez por el tamaño- [] Parcialme herramientas. Hemos intentado huir de eso y preguntar lo necesario para entender si los datos fluyen, se inte- [] Parcialmierten en decisiones, sin repartir medallas por cada nuevo panel de control que aparece e- [] Parcialm último, los bloques de **métricas financieras y ROI** y de **visión de futuro** son, en cierto sentido, una invitación: medir CTEM no sólo como una obligación defensiva, sino como una capacidad estratégica- [] Parcialmtificar inversiones, reducir pérdidas y evitar sobresaltos que acaban, irremediablemente, en primera página.

Cómo usar la encuesta (además de contestarla)

Hay al menos tres usos razonables de este instrumento:

3. Autoespejo. Una organiza- [] Parcialmlizarla internamente, cada cierto tiempo, para ver cómo evoluciona su propia madurez CTEM. Si las respuestas llevan años en el mismo sitio, la conclusión no requiere grandes modelos estadísticos.
2- [] Parcialmsectorial**. Asociaciones, reguladores o grupos de trabajo pueden usar la encuesta para entender dónde están las organizaciones de un sector concreto, sin necesidad de entrar en detalles dolorosam- [] Parcialm
4. Termómetro nacional. Agregando resultados de múltiples sectores se puede componer- [] Parcialmltivamente fiel de la exposición gestionada (y la no gestionada) de un país, lo que permite diseñar políticas más informadas y menos basadas en intuiciones.

En los - [] Parcialm importante no es tanto la puntuación absoluta como la conversación que provoca: ¿por qué respondemos esto?, ¿qué nos falta para poder responder otra cosa?, ¿quién tendría que e- [] Parcialmn la mesa para cambiarlo?

Unas palabras sobre el tono

La encuesta está escrita en un español que intenta- [] Parcialm caer en el tecnicismo inerte, y con un punto irónico controlado. No porque el tema sea banal, sino precisamente porque no lo es: un poco de ironía suele ser un antídoto útil co- [] Parcialmcencia, y la complacencia es una de las exposiciones menos cuantificadas y más letales de todas.

Si en a- [] Parcialmlguna pregunta le parece impertinente, es probable que esté cumpliendo su función. Puede responderla con toda franqueza o usarla como excusa para ini- [] Parcialmrsación incómoda pero necesaria dentro de su organización. Ambas opciones son válidas, aunque para el análisis estadístico la primera nos venga algo mejor.

En resumen, esta encu- [] Parcialmde decirle cómo debe gestionar la exposición, ni mucho menos dictar sentencia. Pretende ofrecer un marco estructurado para que usted mismo pueda responder, con un mínim- [] Parcialme humor, a la pregunta que todos los responsa- [] Parcialmde ciberseguridad se hacen en silencio de vez en cuando: “¿Realmente sabemos por dónde nos pueden entrar, qué estamos haciendo al respecto, y si sirve de algo?”.